



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-48907 Widget Factory Joomla Content Editor Improper Access Control Vulnerability

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-17
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-48907 Widget Factory Joomla Content Editor Improper Access Control Vulnerability - Vulnerability Report

Published: 2026-06-17 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

LBC-VTI-2026-083: CVE-2026-48907 Widget Factory Joomla Content Editor Improper Access Control Vulnerability

1. Executive Summary

CVE-2026-48907 is a critical improper access control vulnerability in the JCE Editor extension for Joomla that permits unauthenticated creation or import of editor profiles. In observed exploitation, attackers create a rogue JCE profile that permits executable file uploads, then use that profile to place PHP web shells or droppers into writable Joomla paths. CISA added the issue to the Known Exploited Vulnerabilities catalog on 2026-06-16 with a due date of 2026-06-19 for covered entities, confirming active exploitation and requiring urgent mitigation.

Lost Boys Cyber assesses this issue as high operational priority for any organization that hosts Joomla sites, manages Joomla portfolios for clients, or relies on Joomla for public web presence. The vulnerability is remotely reachable, requires no authentication or user interaction, has a CVSS v4.0 base score of 10.0 from the Joomla security CNA, and is reported by the vendor and third-party Joomla ecosystem researchers as actively exploited with automated attacks and public working exploit code. Updating to JCE 2.9.99.6 or later closes the entry path, but does not remove already-created malicious profiles, uploaded shells, or post-exploitation persistence.

Field	Assessment
Report ID	LBC-VTI-2026-083
CVE	CVE-2026-48907
Vulnerability class	Improper Access Control / CWE-284
Product	Widget Factory Joomla Content Editor / JCE Editor extension for Joomla
Exploitation status	Confirmed exploited in the wild; CISA KEV-listed 2026-06-16
Severity	Critical; CVSS v4.0 10.0, provider urgency Red
Primary risk	Unauthenticated profile import leading to PHP code upload and remote code execution
Recommended action	Patch to JCE 2.9.99.6 or later, then conduct compromise assessment and cleanup
Confidence	High for vulnerability existence, exploitation status, and primary attack chain; moderate for campaign-level attribution

2. Intelligence Requirement

This report answers the following defensive intelligence requirement:

- What is the operational risk posed by CVE-2026-48907 to Joomla/JCE environments, and what actions should defenders take to identify exposure, detect exploitation, and contain suspected compromise?

The assessment is written for security operations teams, vulnerability managers, managed service providers, and administrators responsible for Joomla sites. The priority is not only version-based patching, but also identifying whether exploitation occurred before patching.

Requirement	Defender question	Answer in this report
Exposure	Which assets are vulnerable?	Joomla sites running JCE versions before the fixed 2.9.99.5/2.9.99.6 line, with

		2.9.99.6 recommended by the vendor after additional hardening.
Exploitation	What should we look for?	Requests to `index.php?option=com_jce&task=profiles.import`, rogue JCE profiles, script-capable upload filetypes, unexpected PHP files in writable directories, and web-shell patterns.
Response	Is patching enough?	No. Patching closes the entry point but does not remove rogue profiles, uploaded shells, or attacker changes.
Prioritization	How urgent is this?	Immediate. CISA KEV due date is 2026-06-19; the vendor reports active automated exploitation and public working exploit code.

3. Source Review and Confidence

Lost Boys Cyber used CISA KEV, NVD/CNA metadata, vendor release notes, the JCE vendor security advisory, and Joomla ecosystem research from mySites.guru to produce this assessment. We did not perform independent exploit reproduction for this report; conclusions are based on source correlation and defender-observable artifacts.

Source	Key contribution	Confidence
CISA Known Exploited Vulnerabilities catalog	Confirms active exploitation, KEV addition date, due date, required action language, product/vendor naming, and ransomware-use status as unknown.	High
NVD CVE record / Joomla CNA data	Confirms description, CVSS v4.0 vector and score, CWE-284 classification, and references to the vendor update.	High
JCE vendor advisory, 2026-06-12	States JCE 2.9.99.5 patched the critical vulnerability, 2.9.99.6 added hardening, exploitation is active and automated, and compromise requires cleanup beyond patching.	High
JCE editor changelog	Confirms 2.9.99.5 fixed insufficient access controls permitting unauthenticated users to upload editor profiles and 2.9.99.6 added additional validation/access-control/file-handling hardening.	High
mySites.guru JCE Profiles Hack analysis	Provides practical indicators: suspicious profile names, upload filetypes, profile import XML, dropped shells, paths, and cleanup workflow.	Medium-High
Public reporting / exploit repository search results	Supports public exploit availability and broad defender attention; used cautiously because some sources may summarize or repackage vendor claims.	Medium

Analyst confidence is high that CVE-2026-48907 enables unauthenticated creation/import of JCE profiles and that current exploitation uses that capability to upload PHP code. Confidence is lower for specific attacker identity, infrastructure ownership, and ransomware linkage because CISA lists known ransomware campaign use as unknown and no authoritative campaign attribution was identified during this review.

4. Key Findings

Finding	Defensive implication	Confidence
CVE-2026-48907 is already exploited in the wild and is in CISA KEV.	Treat affected internet-facing Joomla/JCE sites as emergency patch and triage candidates.	High
The vulnerability allows unauthenticated users to create or import JCE editor profiles.	Blocking anonymous registration or relying on absence of public login is insufficient.	High
The observed attack path is profile creation/import followed by executable file upload.	Detection must include both HTTP profile-import activity and filesystem/database artifacts.	High
Updating JCE closes the entry path but does not remediate an already compromised site.	Incident response must preserve evidence, remove rogue profiles, hunt web shells, and rotate credentials where compromise is suspected.	High
JCE 2.9.99.6 is the recommended remediation target, not merely 2.9.99.5.	Vulnerability management should require 2.9.99.6 or later because the vendor added hardening after the initial fix.	High
Public exploit code and automated attacks increase mass-exploitation likelihood.	Organizations should prioritize portfolio-wide discovery over ticket-by-ticket manual checks.	Medium-High

Attack chain summary:

Stage	Attacker action	Observable evidence
Reconnaissance	Identify reachable Joomla sites using vulnerable JCE builds.	HTTP scanning against Joomla/JCE endpoints; abnormal requests from hosting/VPS ranges.
Initial access	Send unauthenticated request to JCE profile import functionality.	Web logs containing `option=com_jce` and `task=profiles.import` without an authenticated admin session.
Configuration abuse	Create a rogue editor profile that permits PHP or other script uploads.	New row in JCE profile table; suspicious profile names such as `J` plus six digits; labels like `Pwned`; large negative ordering; upload extensions including `php` or `phtml`.
Payload placement	Upload PHP web shell, dropper, or disguised XML/PHP file through the rogue profile.	Unexpected PHP files in `images`, `media`, `tmp`, `media/system/js`, or `libraries/joomla`; filenames containing `.xml.php`; web-shell function patterns.
Post-exploitation	Execute commands, maintain access, deploy additional tooling, alter site content,	Web server process spawning shells; outbound connections from web host;

	or pivot through hosted environment.	modified Joomla/PHP files; credential access attempts.
--	--------------------------------------	--

5. Threat Context

JCE is a widely deployed Joomla editor extension. Its Editor Profiles feature lets administrators assign different editor capabilities to different user groups and workflows. CVE-2026-48907 undermines that boundary by allowing unauthenticated users to import or create profiles, then abusing profile configuration to permit upload of executable server-side code.

The vendor's 2026-06-12 advisory states that JCE 2.9.99.5 was released on 2026-06-03 to patch the critical vulnerability and that 2.9.99.6 followed with additional hardening on 2026-06-08. The same advisory warns that attacks are active and automated, that public registration does not need to be enabled for exploitation, and that a patched site may remain compromised if the attacker already created a rogue profile or uploaded files before the update.

Exposure is especially consequential for public Joomla sites on shared hosting, agency-managed portfolios, and web properties where the web server user has write access to media or extension directories. A single compromised public CMS can become a web-shell foothold, credential collection point, SEO spam node, malware staging location, or pivot into adjacent hosting accounts.

Risk driver	Why it matters
No authentication required	Internet-facing sites can be attacked at scale without valid Joomla accounts.
Low complexity	The attack path is configuration abuse plus file upload rather than a fragile memory corruption exploit.
Automatable	NVD CVSS v4.0 vector marks Automatable as Yes; vendor and ecosystem reporting describe automated attacks.
Public exploit availability	Public working code lowers the barrier for opportunistic actors and copycat campaigns.
Patch-only false negative	Administrators may update JCE and miss already-installed rogue profiles or shells.
Web-shell impact	PHP execution on a public site can support command execution, persistence, defacement, spam, data access, and lateral movement.

MITRE ATT&CK mapping:

Tactic	Technique	Relevance
Initial Access	T1190 - Exploit Public-Facing Application	Exploitation targets a public Joomla/JCE endpoint without authentication.
Persistence	T1505.003 - Server Software Component: Web Shell	Uploaded PHP shells can provide persistent server-side access.
Privilege Escalation / Defense Evasion	T1574 or CMS configuration abuse, context dependent	Rogue profile configuration changes can alter normal permission boundaries and hide in legitimate CMS state.
Command and Control	T1105 - Ingress Tool Transfer	Web shells may fetch second-stage tooling or receive uploaded payloads.
Execution	T1059 - Command and Scripting Interpreter	PHP web shells may invoke OS commands through <code>`shell_exec`</code> , <code>`system`</code> , <code>`passthru`</code> ,

		or similar functions.
Impact	T1496/T1499/T1565, context dependent	Compromised web hosts can be used for resource abuse, disruption, or site/content tampering.

6. Detection and Hunting

Detection should combine web access log review, database/profile review, filesystem inspection, endpoint/process telemetry, and version inventory. Do not rely on one signal. The profile import request may have aged out of access logs, and a web shell may remain after JCE is patched.

Detection surface	High-value signals	Notes
Web access logs	`index.php?option=com_jce&task=profiles.import`, POSTs to JCE profile import functions, unauthenticated requests to editor/profile endpoints.	The earliest matching request can anchor restore and scoping timelines.
Joomla database	Unexpected JCE profiles, machine-generated names like `J` followed by six digits, labels/descriptions such as `Pwned` or `RCE via JCE`, negative ordering, upload extensions including `php`, `phtml`, or script-like types.	Merely enabling PHP inside article content is not the same as allowing script file upload; inspect upload filetype configuration.
Filesystem	Unexpected `.php`, `.phtml`, `.php.xml`, or `.xml.php` files in writable directories, especially `images`, `media`, `tmp`, `media/system/js`, and `libraries/joomla`.	Preserve copies before deletion if incident response or legal review is needed.
File content	`eval(gzinflate(base64_decode(`, `shell_exec(\$_POST`, `system(\$_REQUEST`, `passthru`, `assert`, obfuscated base64/gzip chains, or `Nxploited` markers.	Treat as triage patterns; validate to avoid false positives in legitimate developer tooling.
Process telemetry	Web server processes spawning shells, interpreters, curl/wget, archive tools, or outbound network clients.	Especially relevant for EDR-managed Linux servers.
Network telemetry	Outbound connections from web server to unknown IPs following suspicious uploads.	May indicate post-exploitation staging or C2.

Example Sigma rule for Linux web logs:

<pre> title: Joomla JCE CVE-2026-48907 Profile Import Attempt id: 6e90d87b-60a7-4b9a-9c92-cve202648907-jce-profile-import status: experimental description: Detects HTTP requests consistent with unauthenticated Joomla Content Editor profile import abuse associated with CVE-2026-48907. author: Lost Boys Cyber date: 2026-06-17 references: - https://www.cisa.gov/known-exploited-vulnerabilities-catalog - https://www.joomlacontenteditor.net/news/jce-security-update-and-a-free-patch-for-older-sites logsource: category: webserver </pre>
--

```

detection:
  selection_jce:
    cs-uri-query|contains|all:
      - 'option=com_jce'
      - 'task=profiles.import'
    condition: selection_jce
  fields:
    - c-ip
    - cs-method
    - cs-uri-stem
    - cs-uri-query
    - sc-status
    - cs-user-agent
  falsepositives:
    - Legitimate administrative profile import, though this should not be unauthenticated and should be rare.
  level: high
  tags:
    - attack.initial_access
    - attack.t1190
    - cve.2026.48907

```

Example Microsoft Defender / Sentinel KQL for web logs ingested into a custom table:

```

WebServer_CL
| where TimeGenerated > ago(30d)
| extend uri = strcat(tostring(RequestUri_s), '?', tostring(QueryString_s))
| where uri has 'option=com_jce' and uri has 'task=profiles.import'
| project TimeGenerated, SrcIp=ClientIP_s, Method=Method_s, Uri=uri, Status=StatusCode_s,
UserAgent=UserAgent_s, Host=Host_s
| order by TimeGenerated asc

```

Example KQL for Linux process telemetry where web server processes spawn command interpreters or download utilities:

```

DeviceProcessEvents
| where TimeGenerated > ago(30d)
| where InitiatingProcessFileName in~ ('apache2','httpd','nginx','php-fpm','php-cgi','lsphp')
| where FileName in~
('sh','bash','dash','zsh','curl','wget','python','python3','perl','nc','ncat','socat')
| project TimeGenerated, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine,
InitiatingProcessCommandLine, AccountName
| order by TimeGenerated desc

```

Example SPL for web access logs:

```

index=web sourcetype IN (access_combined,apache:access,nginx:access)
("option=com_jce" AND "task=profiles.import")
| table _time src_ip host method uri status useragent
| sort 0 _time

```

Example Linux filesystem triage commands for an authorized administrator:

```

# Search common writable Joomla paths for unexpected PHP-like files.
find images media tmp media/system/js libraries/joomla \
  -type f \( -iname '*.php' -o -iname '*.phtml' -o -iname '*.php.*' -o -iname '*.xml.php' \) \
  -printf '%TY-%Tm-%Td %TH:%TM %p\n' | sort

# Search for common web-shell strings. Review results before deleting anything.
grep -RInE "eval\s*\(|gzinflate\s*\(|base64_decode\s*\(|shell_exec\s*\(|passthru\s*\(|system\s*\(|
Nxploited" \
  images media tmp media/system/js libraries/joomla 2>/dev/null

```

Example SQL triage pattern; adjust the table prefix for the target Joomla installation:

```

SELECT id, name, description, ordering, published
FROM jos_wf_profiles
WHERE name REGEXP '^J[0-9]{6}$'
      OR description LIKE '%RCE via JCE%'
      OR name LIKE '%Pwned%'
      OR ordering < -1000;

```


Hunting hypotheses:

Hypothesis	Query or review focus	Expected result
Attackers attempted the vulnerable profile import task.	Search web logs for `option=com_jce` and `task=profiles.import`.	Source IPs, timestamps, status codes, and user agents for attempted or successful exploitation.
A rogue profile was installed before patching.	Inspect JCE profile tables and profile configuration for script-capable upload types.	Unknown profile with suspicious name/description/order or upload extensions.
A PHP web shell was uploaded into a writable media path.	Enumerate PHP-like files in `images`, `media`, `tmp`, `media/system/js`, `libraries/joomla`.	Newly created PHP files, disguised `.xml.php` files, or obfuscated content.
Web-shell activity occurred after upload.	Correlate web hits to suspicious PHP files with process/network telemetry.	POST requests to shell paths, web server spawning shell/download tools, outbound connections.
Cleanup was incomplete.	Compare patched JCE version against remaining rogue profiles/files.	Sites that are no longer vulnerable but remain compromised.

7. Recommendations

Immediate response should be treated as both vulnerability management and incident response. Any vulnerable JCE site that was internet reachable before patching should be triaged for compromise.

Priority	Action	Owner	Target timeframe
P0	Inventory all Joomla sites and identify installed JCE versions.	Vulnerability Management / Web Operations	Same day
P0	Upgrade JCE to 2.9.99.6 or later using the vendor-supported update path.	Web Operations	Same day; no later than applicable CISA KEV/BOD deadline for covered entities
P0	Review access logs for `index.php?option=com_jce&task=profiles.import` and related JCE profile import attempts.	SOC / Incident Response	Same day
P0	Inspect JCE profile configuration for rogue profiles and script-capable upload filetypes.	Web Operations / Incident Response	Same day
P0	Hunt for PHP web shells or disguised PHP files in writable Joomla paths.	Incident Response	Same day
P1	Preserve copies of suspicious profiles/files before deletion where evidence handling is required.	Incident Response / Legal	Before cleanup
P1	Remove rogue profiles and	Web Operations / Incident	24 hours

	malicious files, then re-scan the host and site tree.	Response	
P1	Rotate Joomla administrator credentials, hosting panel credentials, database passwords, API keys, and any secrets accessible to the web process if compromise is confirmed.	Identity / Web Operations	24-48 hours
P1	Restore from a known-good backup predating first exploit evidence when integrity cannot be established.	Web Operations / Incident Response	Case dependent
P2	Add recurring detection for JCE profile import attempts and web-shell execution patterns.	Detection Engineering	72 hours
P2	Harden Joomla file permissions and prevent PHP execution in media/upload directories where feasible.	Web Operations	7 days

Operational notes:

- Patch first, then clean. Deleting shells without closing the entry point invites rapid reinfection.
- Do not assume absence of public user registration reduces exposure; vendor guidance states sites without public registration are still unsafe if vulnerable.
- If web access logs have rotated, treat the site as potentially compromised if vulnerable during the active exploitation window and complete filesystem/database triage anyway.
- If malicious PHP files are found, expand scope beyond JCE artifacts. Review user accounts, extension inventory, scheduled tasks/cron, `.htaccess`, template files, recently modified PHP, and outbound network logs.
- For managed service providers, run portfolio-wide discovery and batch patching instead of relying on individual customer tickets.

Hardening controls:

Control	Rationale
Disable PHP execution in upload/media directories using web server configuration.	Reduces impact of future upload-path abuse.
Enforce least-privilege filesystem ownership for the web server user.	Limits where a web shell can be written or modified.
Maintain centralized web access logging with retention beyond 30 days.	Supports timeline reconstruction after vendor advisories.
Monitor CMS extension versions continuously.	CMS plugin vulnerabilities often move from disclosure to exploitation quickly.
Use WAF rules to alert/block suspicious JCE profile import requests.	Provides compensating detection while patching is underway, but is not a substitute for updating.
Conduct post-patch compromise assessment.	Addresses the patch-only blind spot explicitly called out by the vendor.

8. References

- [1] CISA Known Exploited Vulnerabilities Catalog, CVE-2026-48907 entry, added 2026-06-16: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [2] CISA KEV JSON feed, catalog version 2026.06.16: https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json
- [3] NVD CVE-2026-48907 record: <https://nvd.nist.gov/vuln/detail/CVE-2026-48907>
- [4] JCE security update and free patch for older sites, 2026-06-12: <https://www.joomlacontenteditor.net/news/jce-security-update-and-a-free-patch-for-older-sites>
- [5] JCE Editor changelog, 2.9.99.5 and 2.9.99.6 release notes: <https://www.joomlacontenteditor.net/support/changelog/editor>
- [6] mySites.guru, Find and Fix the JCE Profiles Hack, 2026-06-17: <https://mysites.guru/blog/finding-every-site-running-a-vulnerable-jce/>
- [7] MITRE ATT&CK, Exploit Public-Facing Application T1190: <https://attack.mitre.org/techniques/T1190/>
- [8] MITRE ATT&CK, Server Software Component: Web Shell T1505.003: <https://attack.mitre.org/techniques/T1505/003/>